IAM & LEAST PRIVILEGE ENFORCEMENT

Unit 2 — Cloud Security Practical Report

Practical: Create IAM groups (Admins, Developers, Auditors), attach least-privilege custom policies, enforce MFA for Admins, and create an EC2 role for secure S3 access.

Note: Console panels are illustrative mockups, not live AWS screenshots. Capture your own AWS console evidence for submission.

1. Aim

Implement role-based IAM access with least privilege, require MFA for administrators, and allow EC2 to access S3 through temporary role credentials.

2. IAM design

Identity	Permissions
Admins	Administrative tasks; MFA required
Developers	Application bucket object access only
Auditors	Read-only IAM and bucket inspection
EC2-S3-ReadRole	EC2 trust; read objects from one bucket

Replace YOUR-APP-BUCKET with your own test bucket name. Avoid broad permissions and never put access keys in code.

3. Procedure

A. Create groups: IAM → User groups → Create group. Create Admins, Developers, Auditors; assign users and attach matching policies.

Amazon Web Services | Console	Sample account • ap-south-1
User groups	IAM Console
Admins	Policy: Admins-MFA-Guardrails
Developers	Policy: Developers-AppBucket
Auditors	Policy: Auditors-ReadOnly

Illustrative console mockup — replace with your own AWS screenshot.

B. Developer custom policy: list bucket and read/write objects only in the designated bucket. Remove DeleteObject if deletion is not needed.

```
{
"Version":"2012-10-17",
"Statement":[
{"Effect":"Allow","Action":"s3:ListBucket","Resource":"arn:aws:s3:::YOUR-APP-BUCKET"},
{"Effect":"Allow","Action":["s3:GetObject","s3:PutObject"],"Resource":"arn:aws:s3:::YOUR-APP-BUCKET/*"}
]}
```

Amazon Web Services | Console	Sample account • ap-south-1
Policy editor	IAM Console
Policy name	Developers-AppBucket
Actions	ListBucket, GetObject, PutObject
Resources	One bucket and its objects

Illustrative console mockup — replace with your own AWS screenshot.

C. Auditor policy: keep it read-only. Example limited to IAM metadata and bucket listing:

```
{
"Version":"2012-10-17",
"Statement":[{"Effect":"Allow","Action":["iam:List*","iam:Get*"],"Resource":"*"},
{"Effect":"Allow","Action":"s3:ListBucket","Resource":"arn:aws:s3:::YOUR-APP-BUCKET"}]
}
```

D. MFA: IAM → Users → select administrator → Security credentials → Assign MFA device. Enroll an authenticator app or security key. Test with a non-production user. Validate any MFA guardrail before use to avoid administrator lockout.

Amazon Web Services | Console	Sample account • ap-south-1
Administrator security credentials	IAM Console

MFA device	Assigned
Method	Authenticator app / security key
Status	Enabled

Illustrative console mockup — replace with your own AWS screenshot.

E. EC2 role: IAM → Roles → Create role → AWS service → EC2. Attach this scoped policy, name it EC2-S3-ReadRole, then attach it to the instance through EC2 → Actions → Security → Modify IAM role.

```
{
"Version":"2012-10-17",
"Statement":[{"Effect":"Allow","Action":"s3:GetObject","Resource":"arn:aws:s3:::YOUR-APP-BUCKET/*"}]
}
```

Amazon Web Services | Console	Sample account • ap-south-1
Role summary	IAM Console
Trusted entity	ec2.amazonaws.com
Permission	GetObject on one bucket
Attached to	EC2 test instance
Credentials	Temporary role credentials; no keys stored

Illustrative console mockup — replace with your own AWS screenshot.

4. Verification

Test	Expected result
Admin protected action without MFA	Denied
Developer accesses approved bucket	Allowed
Developer changes IAM / accesses other bucket	Denied
Auditor modifies policy or object	Denied
EC2 reads approved S3 object	Allowed
EC2 writes or reads unrelated bucket	Denied

Record actual results and add your own screenshots of group membership, policy JSON, MFA status, role trust relationship, role attachment, and access tests.

5. Result

The IAM groups separate administrative, developer, and audit permissions. MFA strengthens administrator sign-in, and EC2 accesses S3 through an IAM role without hardcoded credentials.

Security note

Use a test account and non-sensitive data. IAM permissions may also be affected by resource policies, permission boundaries, SCPs, and explicit denies. Remove test resources and unused access after completion.